

# Web & Netowrk Pentration Testing

## Team Members

- Sherif Mohamed Mosallam
  - Kirolos Gamil Samy
  - Alaa Mohamed Goma
  - Mostaf Mohamed Abdo
- 

## Objective

### Netwrok Pentest:

Identify, exploit, and help fix weaknesses in network infrastructure (machines, services, protocols) before attackers do.

1. **Scoping and setting expectations**
2. **Reconnaissance and vulnerability discovery**
3. **Exploitation and privilege escalation**
4. **Post-exploitation and persistence testing**
5. **Reporting and remediation planning**

### Web App Pentest:

Find and exploit vulnerabilities in a web application to prevent real attackers from abusing them.

1. **Input Handling (User → Server)**
2. **Authentication (Login Systems)**
3. **Authorization (Access Control)**
4. **Session Management**

5. Business Logic Flaws

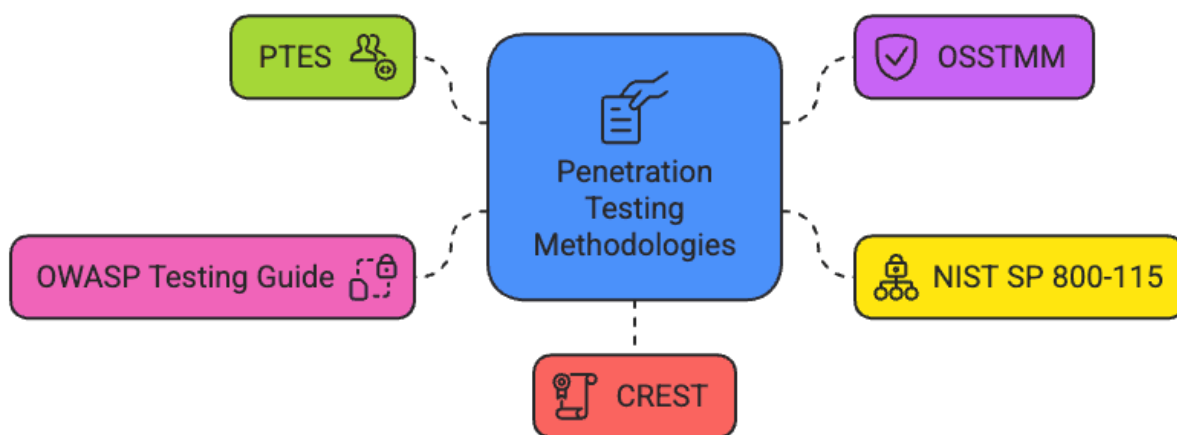
6. File Handling

7. Configuration Issues

---

## Methodology

### Network Penetration Testing Methodologies



We follow PTES → Penetration Testing Execution Standard:

- **Pre-engagement Interactions** – Define scope, set expectations, lock down legalities.
- **Intelligence Gathering** – Passive and active recon. From WHOIS to subdomain scraping to OSINT crawling, this is where the war starts.
- **Threat Modeling** – Understand the business context. Know what matters. Prioritize what breaks the business, not just the firewall.
- **Vulnerability Analysis** – Identify weaknesses using both automation and manual digging. Tools help; brains win.
- **Exploitation** – Prove impact. Gain access, escalate privileges, pivot—ethically.
- **Post-Exploitation** – What can you do with what you've got? Lateral movement, persistence, data exfiltration simulations.

- **Reporting** – No fluff. Real impact, reproduction steps, and remediation.

## What We Test

- **Open ports & services** (what's exposed?)
  - **Service vulnerabilities** (outdated software, known exploits)
  - **Authentication** (weak passwords, default creds)
  - **Network misconfigurations** (poor firewall rules, exposed shares)
  - **Internal trust relationships** (lateral movement between machines)
- 

## Common Issues

- Open unnecessary ports
  - Weak or reused passwords
  - Unpatched systems
  - Misconfigured firewalls
  - Exposed services (SSH, SMB, RDP)
- 

## Common tools used for network penetration testing

- **Nessus:** A commercial vulnerability scanner that identifies and helps remediate security vulnerabilities and misconfigurations.
- **Nmap:** An open-source network scanning tool for discovery, port mapping, and vulnerability assessment.
- **Metasploit:** An exploitation framework for discovering and testing vulnerabilities, with a large library of exploits.
- **Wireshark:** A network protocol analyzer for capturing and inspecting packets in real time.
- **Burp Suite:** A web proxy and vulnerability scanner for analyzing and securing web applications.

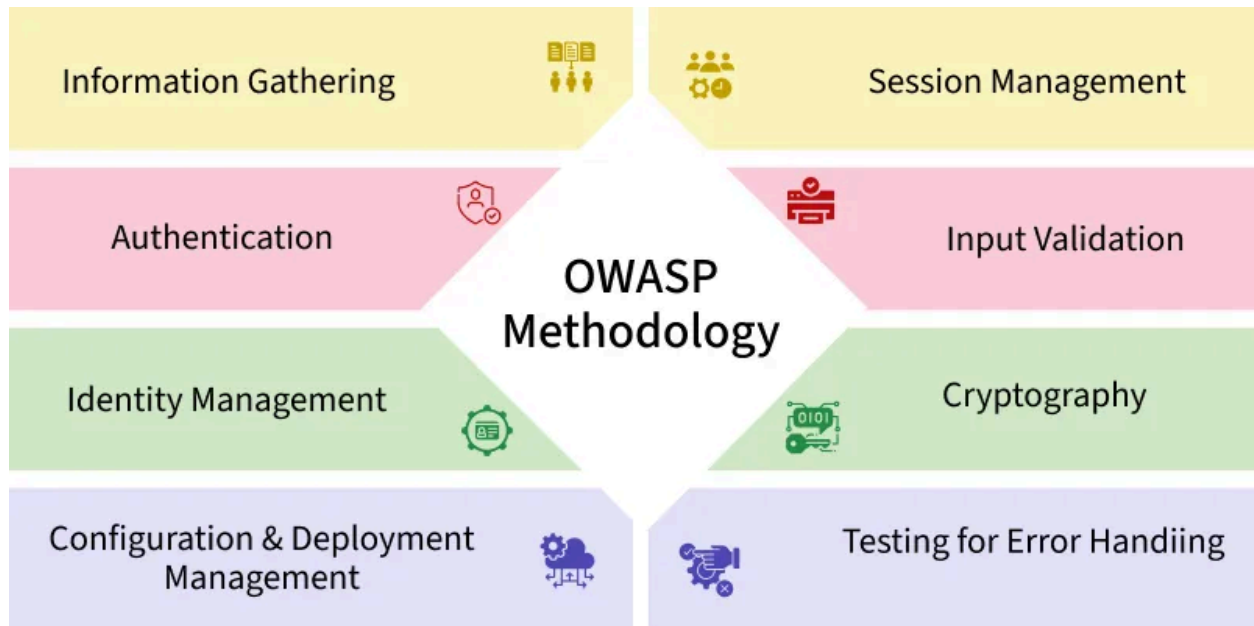
- **Intruder:** A cloud-based vulnerability scanner that identifies security weaknesses and provides actionable insights.

## Web App Pentesting Methodology

### We follow OWASP – Web Security Testing Guide (WSTG)

The OWASP Web Security Testing Guide (WSTG) is one of the most comprehensive and globally recognized resources for web application security testing. It is maintained by the Open Web Application Security Project (OWASP) and built by a global community of cybersecurity professionals.

The WSTG provides a structured set of test cases that penetration testers and security auditors can follow to assess the security posture of any web application.



## Tools For Web App Pentesting

### Tools For Web App Pentesting

|    |                   |    |                             |
|----|-------------------|----|-----------------------------|
| 01 | <b>Burp Suite</b> | 06 | <b>Dirb / Gobuster</b>      |
| 02 | <b>OWASP ZAP</b>  | 07 | <b>Hydra</b>                |
| 03 | <b>Nikto</b>      | 08 | <b>Metasploit</b>           |
| 04 | <b>SQLmap</b>     | 09 | <b>WFuzz</b>                |
| 05 | <b>Nmap</b>       | 10 | <b>Wappalyzer / WhatWeb</b> |

1. **Burp Suite:** Intercepts, modifies, and analyzes HTTP/S traffic.
2. **OWASP ZAP (Zed Attack Proxy):** Open-source tool for automated scanning and manual testing.
3. **Nikto:** Web server scanner for outdated software, misconfigurations, and vulnerabilities.
4. **SQLmap:** Automates SQL injection detection and exploitation.
5. **Nmap:** For port scanning, service discovery, and basic enumeration.
6. **Dirb / Gobuster:** Directory and file brute-forcing tools.
7. **Hydra:** Password brute-forcing tool for login forms.
8. **Metasploit:** Exploitation framework for testing discovered vulnerabilities.
9. **WFuzz:** Web application fuzzer for brute-forcing parameters.
10. **Wappalyzer / WhatWeb:** Identifies web technologies (CMS, frameworks, servers).

---

### What We Test

- **Input validation** → injections (SQLi, XSS)

- **Authentication** → login weaknesses
  - **Authorization** → access control (can users do more than they should?)
  - **Sessions** → cookies, tokens, hijacking
  - **Business logic** → flaws in how the app works
  - **Configuration** → exposed files, debug settings
- 

### **Common Vulnerabilities**

Defined by OWASP:

- SQL Injection
  - XSS (Cross-Site Scripting)
  - Broken Access Control
  - Authentication flaws
  - Misconfigurations
- 

### **Summary: Purpose of Network and Web Penetration Testing**

Network and web penetration testing are conducted to **proactively identify, validate, and mitigate security vulnerabilities** across an organization's infrastructure and applications. By simulating real-world attack scenarios, these assessments provide a practical understanding of how an attacker could gain unauthorized access, escalate privileges, or compromise sensitive data.

Network penetration testing focuses on evaluating the security of internal and external infrastructure, including hosts, services, and communication channels. It aims to uncover weaknesses such as misconfigurations, unpatched systems, and insecure protocols that could allow unauthorized access or lateral movement within the network.

Web penetration testing targets application-layer vulnerabilities in websites and APIs, including input validation flaws, authentication weaknesses, access control issues, and misconfigurations. These tests help identify risks that could lead to

data breaches, account compromise, or unauthorized actions within the application.

Both testing approaches align with industry best practices such as those outlined by OWASP and are essential for assessing the effectiveness of existing security controls.

Ultimately, the goal of penetration testing is not only to discover vulnerabilities but also to **assess their real-world impact and provide actionable remediation guidance**, enabling organizations to strengthen their security posture, reduce risk exposure, and protect critical assets against potential cyber threats.